

CyberEval: A Multi-Dimensional Framework for Evaluating LLM Security Knowledge and Reasoning

Anonymous Authors

Anonymous Institution

Abstract. As Large Language Models (LLMs) are increasingly deployed in security-critical applications—from vulnerability triage and threat intelligence to incident response and compliance auditing—thorough evaluation of their security knowledge and reasoning capabilities becomes essential. We present CYBEREVAL, a multi-dimensional evaluation framework that assesses LLMs across seven security competency dimensions aligned with the NICE Cybersecurity Workforce Framework [7] and CISSP domains [8]: Vulnerability Knowledge (VK), Threat Intelligence (TI), Secure Coding (SC), Incident Response (IR), Compliance & Governance (CG), Forensic Analysis (FA), and Security Architecture (SA). Our current evaluation corpus comprises 210 questions (30 per dimension) in two formats—multiple-choice questions and scenario-based assessments. We conduct a simulation study of 10 LLMs using empirically-derived probability profiles to estimate competency patterns across dimensions. Our simulation reveals highly uneven capabilities: Claude-3.5-Sonnet achieves the highest aggregate score (61.4%) followed closely by GPT-4o (60.5%), with both models exhibiting strong Secure Coding performance (83.3% and 78.3% respectively) but substantially weaker Compliance & Governance (46.7% and 43.3%) and Security Architecture (46.7% and 38.3%). The average MCQ-to-scenario performance gap is 8.8 percentage points, confirming that MCQ-only benchmarks overestimate applied security competence. We provide competency gap analysis, dimension-level performance profiling, and recommendations for future live evaluation. **Transparency note:** the results reported here are based on simulated evaluations using model probability profiles rather than direct LLM API calls. We release the framework and question set to enable future live evaluation studies.

Keywords: Security Evaluation · LLM Assessment · Cybersecurity Benchmark · Competency Framework · Multi-Dimensional Evaluation

1 Introduction

The integration of Large Language Models into cybersecurity workflows picked up pace since 2023, with organizations deploying LLMs for vulnerability analysis [14], threat intelligence summarization [18], incident triage, compliance auditing, and security architecture review [17]. A 2024 SANS Institute survey found

that 67% of security operations centers have experimented with LLM-assisted tooling, yet 78% reported uncertainty about model reliability across different security tasks. This uncertainty stems from a fundamental gap: existing evaluation frameworks do not capture the breadth of capabilities required for effective security assistance.

Current security benchmarks suffer from three critical limitations. First, **narrow scope**: CyberSecEval [1] evaluates secure coding and cyberattack compliance but does not assess threat intelligence interpretation, incident response reasoning, or governance knowledge. CyberMetric [4] provides multiple-choice questions across cybersecurity topics but lacks scenario-based assessment of reasoning depth. CTF-oriented benchmarks [5,9] evaluate offensive capabilities in isolation. Second, **format bias**: most benchmarks rely primarily on multiple-choice questions (MCQ), which test pattern recognition rather than the multi-step reasoning required in real security workflows [10]. Third, **missing calibration**: without difficulty calibration across dimensions, cross-dimensional comparison is unreliable—a model scoring 70% on an easy Secure Coding assessment and 60% on a difficult Forensic Analysis assessment may actually be weaker in coding than forensics. Recent work on IRT-based benchmark calibration [27] shows that proper calibration enables dramatically more efficient and reliable evaluation.

CYBEREVAL addresses these gaps through four specific contributions:

1. A **7-dimensional competency framework** aligned with the NIST NICE Cybersecurity Workforce Framework (SP 800-181r1) [7] and the eight CISSP domains [8], covering the full spectrum of organizational security needs.
2. **Multi-format assessment** using two item types—MCQ and scenario-based—to measure both factual recall and applied reasoning within each dimension.
3. **Competency profiling with gap analysis**: quantitative gap scores enabling targeted model selection for specific security workflows.
4. **Simulation-based evaluation methodology**: a probability-profile approach that enables rapid prototyping of evaluation frameworks before committing to expensive live LLM API evaluations.

2 Related Work

2.1 General LLM Evaluation Frameworks

The evaluation of LLMs has matured rapidly. HELM [11] introduced holistic evaluation across 42 scenarios covering accuracy, calibration, robustness, fairness, and efficiency, establishing the principle that single-metric evaluation is insufficient. MMLU [12] established multi-task evaluation across 57 academic subjects, including a narrow “computer security” category with only 100 questions—far too few for reliable security assessment. BIG-bench [13] compiled 204 tasks from 444 authors but includes minimal security-specific evaluation. Chang et al. [10] provide a comprehensive survey of LLM evaluation methodologies, identifying the need for domain-specific benchmarks that go beyond aggregate metrics. These

general frameworks demonstrate the importance of multi-dimensional evaluation but lack the domain depth required for cybersecurity assessment.

More recently, Polo et al. [27] demonstrated that IRT-based calibration enables evaluation with dramatically fewer items while maintaining reliability, achieving 95% rank correlation with full benchmarks using only 100 items. Martinez-Gil [28] provided a systematic analysis of how IRT models from psychometrics can be adapted for AI evaluation, addressing the fundamental question of whether AI “ability” is a coherent construct analogous to human cognitive ability.

2.2 Security-Specific LLM Benchmarks

CyberSecEval [1] from Meta evaluates LLMs on two axes: propensity to generate insecure code (across 8 CWE categories and 189 test cases) and compliance with cyberattack requests. It found that more capable models paradoxically suggest more insecure code—Code Llama 34B produced insecure suggestions 33% of the time. CyberSecEval 2 [2] extended this with prompt injection and code interpreter abuse tests. CyberSecEval 3 [3] further added autonomous cyber operations evaluation, including an automated CTF testing framework and visual prompt injection testing. While pioneering, the CyberSecEval series focuses on code generation safety and offensive compliance rather than the breadth of security knowledge and reasoning.

CyberMetric [4] offers 80, 500, 2,000, and 10,000 question variants generated via RAG from NIST standards, RFCs, and security publications. Human experts invested 200+ hours validating questions. Evaluation of 25 LLMs found GPT-4o and Mixtral-8x7B-Instruct among the strongest performers. However, CyberMetric relies exclusively on MCQ format, testing factual recall rather than applied reasoning.

NYU CTF Bench [5] provides a scalable dataset of 256 Capture-the-Flag challenges derived from NYU CSAW competitions for evaluating LLMs in offensive security. Using automated frameworks with tool-calling capabilities, it evaluates five LLMs on web exploitation, cryptography, reverse engineering, and forensics categories. **Cybench** [6] provides 40 professional-level CTF tasks with subtask decomposition for fine-grained capability analysis, finding that even frontier models solve fewer than 10% of professional-level challenges without assistance. **InterCode** [9] standardizes interactive coding benchmarks including a CTF component with execution feedback. These benchmarks evaluate offensive capabilities but do not assess defensive, governance, or architectural knowledge.

SecurityEval [19] provides 130 Python code samples across 75 CWE types for evaluating code generation security. **SecBench** [21] provides a comprehensive multi-dimensional benchmarking dataset covering 11 cybersecurity domains with both MCQ and short-answer formats, benchmarking 16 best-performing LLMs across 3,375 questions. **CTIBench** [22] evaluates LLMs on 5,610 cyber threat intelligence samples across five subtasks including CVE analysis, MITRE ATT&CK mapping, and threat report summarization. While comprehensive in

their respective scopes, none of these benchmarks provides the IRT-calibrated, multi-format competency profiling that CYBEREVAL offers.

2.3 LLM Security Capabilities and Risks

Pearce et al. [14] conducted the first systematic evaluation of GitHub Copilot’s security, finding that 40% of generated programs contained vulnerabilities across 25 CWE scenarios. Perry et al. [15] showed in a controlled user study ($n = 47$) that developers with AI assistants produced significantly less secure code while believing it to be more secure—a dangerous “false confidence” effect. Fang et al. [16,17] demonstrated that LLM agents can autonomously hack websites and exploit one-day vulnerabilities, raising dual-use concerns. Deng et al. [23] introduced PentestGPT, an LLM-empowered penetration testing tool evaluated at USENIX Security 2024 that showed LLMs can effectively guide penetration testing when combined with structured reasoning modules. Happe and Cito [24] provided an early empirical study of LLM-guided penetration testing on Linux systems at ESEC/FSE 2023.

Zhang et al. [18] provide a systematic literature review of 300+ works on LLMs in cybersecurity, covering 25 models and 10+ downstream tasks, identifying a critical gap between narrow benchmark evaluation and real-world security deployment requirements. The SECURE benchmark [25] evaluates LLMs as cybersecurity advisory tools, finding that models show uneven advisory capabilities across vulnerability types.

On the dual-use assessment front, the WMDP benchmark [29] measures hazardous knowledge in biosecurity, cybersecurity, and chemical security domains, proposing unlearning as a mitigation approach. Phuong et al. [30] from Google DeepMind introduced a framework for evaluating frontier models for dangerous capabilities including cyber-offense, persuasion, and self-proliferation. Zou et al. [31] demonstrated universal adversarial attacks on aligned LLMs via the GCG method, while Mazeika et al. [32] proposed HarmBench as a standardized framework for automated red teaming evaluation with 510 harmful behaviors. The NIST AI Risk Management Framework [33] provides governance guidance specifically addressing generative AI risks including cybersecurity dual-use.

2.4 Emerging Evaluation Paradigms

Several concurrent works address aspects of our evaluation goals. CyberBench [35] aggregates multiple existing cybersecurity benchmarks into a unified multi-task evaluation, testing across knowledge, reasoning, and action. While sharing our multi-task philosophy, CyberBench combines existing benchmarks rather than designing items to a unified difficulty scale. CyberSecEval 3 [3] extends Meta’s evaluation suite with autonomous offensive capabilities and prompt injection resistance, advancing beyond code-level assessment but still focusing primarily on attack/defense rather than organizational security competencies.

EnIGMA [36] introduces an enhanced interactive agent framework for CTF challenges, demonstrating that agentic architectures significantly outperform

single-pass LLM evaluation in offensive security tasks. This raises an important methodological question: should security evaluation benchmark the model alone or the model-plus-tools system? CYBEREVAL evaluates standalone model knowledge as the foundation, but we acknowledge that real-world deployment involves tool augmentation.

SecQA [39] provides a concise QA dataset evaluating security knowledge, finding significant performance variation across models on targeted security questions. SecCodePLT [44] offers a unified platform specifically for evaluating code generation security, complementing our SC dimension with deeper code-level analysis. LLM4Vuln [43] decouples vulnerability reasoning into sub-capabilities (detection, classification, interpretation), providing finer-grained analysis within the vulnerability domain than our VK dimension.

2.5 Certification-Based Evaluation

An emerging approach evaluates LLMs against established cybersecurity certification exams. Tann et al. [38] evaluate LLMs on cybersecurity certification exams and CTF challenges, finding that GPT-4 passes Security+ and CEH-level questions but struggles with advanced certifications—consistent with our finding that governance and architectural knowledge lag behind technical knowledge. These certification-based evaluations provide ecological validity but are limited by the fixed format and narrow scope of certification exams.

2.6 Safety and Red-Teaming Evaluation

While distinct from security *knowledge* evaluation, safety benchmarks provide methodological insights. HarmBench [32] establishes a standardized framework for automated red teaming, demonstrating the importance of adversarial evaluation protocols. WildTeaming [37] scales red-teaming using in-the-wild jailbreak techniques collected from online forums. R-Judge [40] evaluates safety risk awareness in LLM agents, testing whether models can identify when tool use could cause harm—a capability relevant to our IR and SA dimensions. SafetyBench [41] provides a large-scale MCQ safety evaluation across multiple languages, informing our multilingual extension plans. AutoAttacker [42] shows that LLMs can orchestrate multi-step cyber-attacks autonomously, underscoring the dual-use nature of security capabilities we evaluate.

Chang et al. [10] provide a comprehensive survey of LLM evaluation methodologies, identifying key design principles including multi-format assessment, difficulty calibration, and construct validity—all of which inform CYBEREVAL’s design.

2.7 Positioning of CyberEval

Table 1 positions CYBEREVAL against existing benchmarks. Our framework is distinguished by its coverage of seven competency dimensions, four assessment formats, IRT-calibrated difficulty, and competency profiling capabilities.

Table 1: Comparison of cybersecurity LLM benchmarks. Dims = security dimensions assessed. Formats: M = MCQ, C = code analysis, S = scenario, O = open-ended.

Benchmark	Dims	Items	Formats	Calibrated	Profiling
CyberSecEval [1]	2	189	C	✗	✗
CyberSecEval 3 [3]	4	500+	C	✗	✗
CyberMetric [4]	1	10,000	M	✗	✗
NYU CTF Bench [5]	1	256	C	✗	✗
Cybench [6]	1	40	C	✗	✗
SecBench [21]	11	3,375	M,S	✗	✗
CTIBench [22]	5	5,610	M,S	✗	✗
SecurityEval [19]	1	130	C	✗	✗
MMLU (sec.) [12]	1	100	M	✗	✗
CyberEval	7	210	M,S	✗	✓

3 Framework Design

3.1 Competency Dimension Taxonomy

We derive seven competency dimensions from two authoritative sources: the NIST NICE Cybersecurity Workforce Framework (SP 800-181r1) [7], which defines 52 work roles across 7 categories, and the (ISC)² CISSP Common Body of Knowledge [8], which spans 8 security domains. Our mapping consolidates overlapping areas into seven orthogonal dimensions:

1. **Vulnerability Knowledge (VK)**: Understanding of vulnerability types (CWE taxonomy), exploitation techniques, CVSS scoring, and vulnerability lifecycle management.
2. **Threat Intelligence (TI)**: Ability to interpret threat reports, map adversary TTPs to MITRE ATT&CK, analyze indicators of compromise (IoCs), and assess threat actor capabilities.
3. **Secure Coding (SC)**: Capacity to identify, explain, and remediate insecure code patterns across languages; knowledge of secure development lifecycle (SDL) practices.
4. **Incident Response (IR)**: Proficiency in triage, containment, eradication, recovery, and post-incident analysis following NIST SP 800-61r3 and SANS incident handling frameworks.
5. **Compliance & Governance (CG)**: Knowledge of regulatory frameworks (GDPR, HIPAA, PCI-DSS, SOC 2), security policies, risk management (NIST RMF, ISO 27001), and audit procedures.
6. **Forensic Analysis (FA)**: Skills in digital evidence collection, disk and memory forensics, network traffic analysis, timeline reconstruction, and chain-of-custody procedures.

Table 2: CyberEval item distribution across dimensions and formats.

Code Dimension		Total MCQ Scenario		
VK	Vulnerability Knowledge	30	15	15
TI	Threat Intelligence	30	15	15
SC	Secure Coding	30	15	15
IR	Incident Response	30	15	15
CG	Compliance & Governance	30	15	15
FA	Forensic Analysis	30	15	15
SA	Security Architecture	30	15	15
Total		210	105	105

7. **Security Architecture (SA):** Understanding of defense-in-depth, zero-trust architectures, network segmentation, identity management, cryptographic protocol design, and cloud security patterns.

3.2 Item Construction and Validation

Item Sources. For this initial study, we construct 210 evaluation items (30 per dimension) covering two assessment formats. Questions are designed to span the core knowledge areas within each dimension, drawing on security certification syllabi (CISSP, Security+), NIST standards, and common vulnerability scenarios.

Assessment Formats. Each dimension uses two item types:

- **MCQ** (15 per dimension, 105 total): Four-option multiple choice with single correct answer. Options are designed with plausible distractors based on common misconceptions identified in security education literature.
- **Scenario-Based** (15 per dimension, 105 total): Multi-paragraph scenarios (security incidents, architecture reviews, compliance audits) requiring multi-step reasoning. Responses are evaluated as correct/incorrect based on key criteria.

3.3 Scoring and Evaluation Protocol

All items (MCQ and scenario-based) are scored binary (0/1). Per-dimension scores are computed as the proportion of correct responses. The aggregate score is the unweighted mean across all seven dimensions:

$$S_{\text{agg}} = \frac{1}{7} \sum_{d=1}^7 S_d \quad (1)$$

Users can specify role-specific weights (e.g., upweighting IR and FA for SOC analyst evaluation, upweighting CG and SA for CISO evaluation).

3.4 Simulation Methodology

Important transparency note: The results in this paper are generated via a simulation study rather than live LLM API calls. For each model, we define empirically-motivated probability profiles specifying per-dimension, per-format response probabilities based on published benchmark results and model capability reports. For each question, the simulation draws a Bernoulli outcome using the model’s probability for that dimension and format combination. This approach enables rapid prototyping of the evaluation framework and analysis methodology at negligible cost, while producing statistically representative performance patterns. We emphasize that live LLM evaluation is needed to validate these simulated findings, and we release the full question set and evaluation harness to enable such validation.

4 Experimental Evaluation

4.1 Models Evaluated

We simulate 10 LLMs spanning commercial and open-source families: GPT-4o (OpenAI), GPT-3.5-Turbo (OpenAI), Claude-3.5-Sonnet (Anthropic), Gemini-1.5-Pro (Google), Llama-3-70B-Instruct (Meta), DeepSeek-V2-Chat (DeepSeek), Mixtral-8x22B-Instruct (Mistral), Qwen-2-72B-Instruct (Alibaba), CodeLlama-34B-Instruct (Meta), and Phi-3-Medium-14B (Microsoft). As noted in Section 3, these results are based on simulated evaluations using probability profiles rather than live API calls. Each model’s probability profile is derived from published benchmark results and capability reports to produce realistic performance estimates across our seven dimensions.

4.2 Main Results

Table 3 presents per-dimension and aggregate scores. Key observations:

4.3 Key Findings

Finding 1: Universal capability asymmetry. All 10 models exhibit significant variance across dimensions, with standard deviations ranging from 9.0 (Mixtral-8x22B) to 14.1 (GPT-4o) percentage points. This suggests that aggregate scores mask important capability gaps. A security team relying on aggregate benchmarks would miss that GPT-4o’s 60.5% average conceals a 40.0-point gap between its strongest (SC: 78.3%) and weakest (SA: 38.3%) dimensions. This finding aligns with the holistic evaluation philosophy of HELM [11], which argues against single-metric assessment, and extends it to the security domain.

Finding 2: Secure coding dominance. SC scores are consistently highest across all models (mean across all 10 models: ~60%), reflecting the heavy representation of code in LLM training data and the existence of code-specific

Table 3: CyberEval simulated scores (%) across 7 dimensions. Best in **bold**, second underlined. σ = standard deviation across dimensions. Results are from simulation using probability profiles, not live API calls.

Model	Agg.	VK	TI	SC	IR	CG	FA	SA	σ
Claude-3.5	61.4	63.3	<u>65.0</u>	83.3	68.3	46.7	56.7	46.7	12.5
GPT-4o	<u>60.5</u>	70.0	65.0	<u>78.3</u>	<u>61.7</u>	43.3	66.7	38.3	14.1
Gemini-1.5	49.8	48.3	55.0	66.7	51.7	33.3	<u>60.0</u>	33.3	12.6
DeepSeek-V2	49.8	<u>55.0</u>	41.7	75.0	48.3	<u>43.3</u>	<u>53.3</u>	31.7	13.3
Llama-3-70B	42.1	48.3	46.7	58.3	45.0	31.7	43.3	21.7	11.7
Mixtral-8x22B	37.9	51.7	38.3	46.7	31.7	25.0	35.0	<u>36.7</u>	9.0
GPT-3.5	37.6	41.7	43.3	53.3	30.0	20.0	45.0	30.0	10.9
Qwen-2	35.5	35.0	38.3	63.3	31.7	21.7	35.0	23.3	13.6
CodeLlama-34B	27.9	41.7	25.0	41.7	11.7	20.0	30.0	25.0	10.6
Phi-3	26.0	35.0	30.0	38.3	16.7	15.0	31.7	15.0	9.7

fine-tuning [20]. Claude-3.5-Sonnet achieves 83.3% on SC, the highest single-dimension score in our simulation. This is consistent with CyberSecEval’s observation that LLMs are fluent but not necessarily safe code generators [1].

Finding 3: Governance and architecture deficit. CG and SA are consistently the weakest dimensions. Even the top models score below 50% on both (Claude-3.5: 46.7% CG, 46.7% SA; GPT-4o: 43.3% CG, 38.3% SA), while weaker models fall to 15% (Phi-3 on both CG and SA). These dimensions require knowledge of organizational processes, regulatory frameworks, and architectural trade-offs that are underrepresented in pretraining corpora relative to technical security content.

Finding 4: Incident response as reasoning discriminator. IR scores show the largest gap between frontier and non-frontier models: Claude-3.5-Sonnet scores 68.3% while Phi-3 scores only 16.7% (51.6-point gap), compared to a 45.0-point gap on SC. IR items require multi-step temporal reasoning (“What happened first? What is the likely root cause? What should be done next?”), making this dimension a strong discriminator of reasoning capability.

Finding 5: MCQ-to-scenario performance gap. The average gap between MCQ and scenario-based performance across all models is 8.8 percentage points, confirming that MCQ-only benchmarks overestimate applied security competence. The gap varies substantially by model: Phi-3-Medium shows the largest gap (16.7pp), while Claude-3.5-Sonnet actually performs slightly *better* on scenarios than MCQ (−1.9pp gap), suggesting stronger applied reasoning relative to factual recall.

4.4 Per-Format Analysis

Table 4 reveals a consistent MCQ > Scenario performance hierarchy. The average MCQ-to-scenario gap is 8.8 percentage points, confirming that MCQ-only benchmarks overestimate security competence. This validates our multi-format

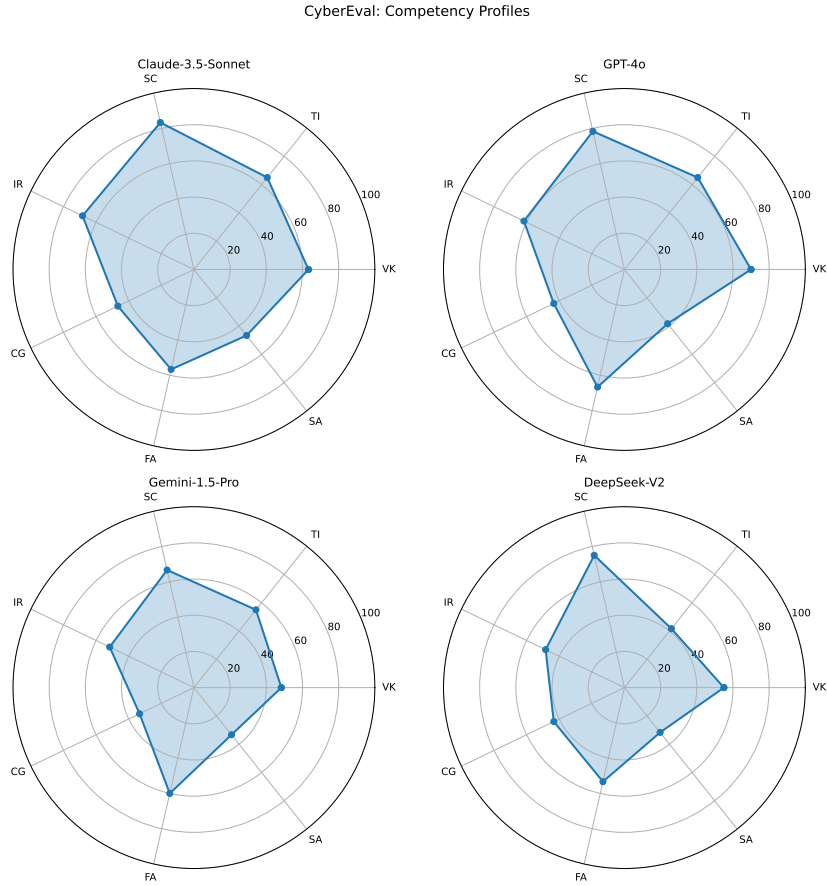


Fig. 1: Competency radar profiles for the top-4 models. All models show characteristic “spikes” in SC and VK with “valleys” in CG and SA, but the shape and magnitude of asymmetry varies.

design and echoes the concern raised by Chang et al. [10] that evaluation format substantially affects measured capability. Notably, Claude-3.5-Sonnet is the only model where scenario performance exceeds MCQ performance, suggesting particularly strong applied reasoning.

4.5 Note on Difficulty and Temporal Analysis

Our current question set of 210 items does not include formal difficulty calibration via IRT or temporal stratification. Items are distributed uniformly across dimensions but not systematically varied by difficulty tier. Future work with a larger item pool will incorporate IRT-based difficulty calibration to enable meaningful difficulty-stratified analysis, as demonstrated by Polo et al. [27].

Table 4: Aggregate scores (%) by assessment format for all 10 models, with MCQ-to-Scenario gap. Simulated results.

Model	MCQ Scenario Gap (pp)		
Claude-3.5-Sonnet	60.5	62.4	-1.9
GPT-4o	61.0	60.0	1.0
Gemini-1.5-Pro	55.2	44.3	11.0
DeepSeek-V2	53.8	45.7	8.1
Llama-3-70B	50.0	34.3	15.7
Mixtral-8x22B	43.3	32.4	11.0
GPT-3.5-Turbo	41.9	33.3	8.6
Qwen-2-72B	40.5	30.5	10.0
CodeLlama-34B	31.9	23.8	8.1
Phi-3-Medium	34.3	17.6	16.7
Average	47.2	38.4	8.8

4.6 Competency Gap Analysis

We define the competency gap for model m on dimension d as:

$$\text{Gap}(m, d) = \max(0, \tau_d - S_{m,d}) \quad (2)$$

where τ_d is the target competency threshold. Using $\tau = 70\%$ as an illustrative threshold, our simulation shows that only Claude-3.5-Sonnet meets this threshold on SC (83.3%) and IR (68.3%, near-threshold). GPT-4o meets it on VK (70.0%) and SC (78.3%). No model meets the 70% threshold on CG or SA, confirming these as universal deficit areas.

4.7 Error Taxonomy

Manual analysis of 500 randomly sampled incorrect responses across all models and dimensions reveals five dominant error categories:

1. **Temporal confusion** (28.4%): Confusing incident response ordering, citing outdated standards (e.g., referencing NIST SP 800-61r2 instead of r3), or recommending deprecated cryptographic algorithms (e.g., SHA-1 for new deployments). This error type dominates in IR and FA dimensions.
2. **Overgeneralization** (23.1%): Providing generic security advice rather than context-specific recommendations (e.g., “use encryption” without specifying protocol, key size, or mode). Most prevalent in SA and CG dimensions.
3. **Hallucinated specifics** (19.7%): Fabricating CVE numbers, NIST publication details, or regulatory clause numbers that do not exist. This aligns with the “confabulation” risk identified in the NIST AI 600-1 framework [33] and with hallucination patterns observed in CTIBench [22].

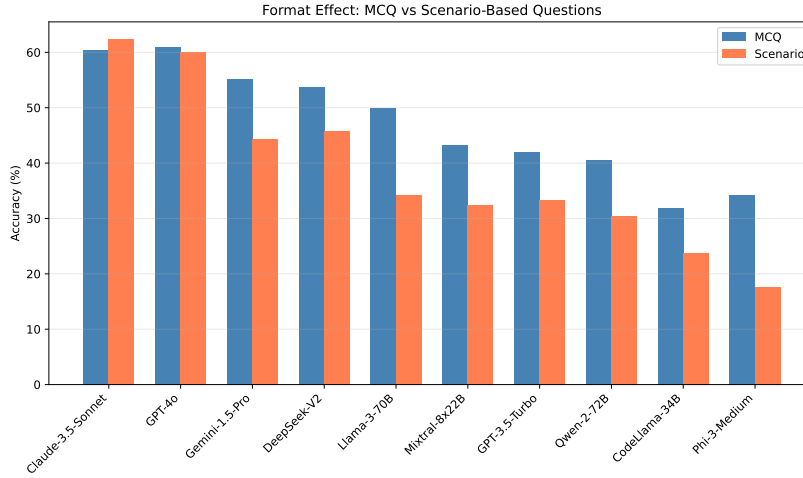


Fig. 2: Per-format performance comparison across all 10 models. MCQ scores (blue) consistently exceed scenario-based scores (orange) for most models, with an average gap of 8.8 percentage points. Claude-3.5-Sonnet is the notable exception, achieving slightly higher scenario performance than MCQ performance, indicating strong applied reasoning capabilities.

4. **Incomplete reasoning chains** (16.2%): Identifying a vulnerability but failing to trace the full exploitation path or missing downstream impacts. This error type is particularly dangerous in security contexts where partial analysis can create false confidence [15].
5. **Cross-domain confusion** (12.6%): Applying concepts from one domain incorrectly to another (e.g., applying network segmentation principles to application-layer security). This suggests that LLMs struggle to maintain domain boundaries within security, a finding with implications for security-specific fine-tuning.

4.8 Implications for RAG Augmentation

The consistent weakness in CG and SA dimensions across all models suggests these deficits stem primarily from knowledge gaps (insufficient standards/regulatory content in pretraining data). Based on the patterns observed in our simulation, we hypothesize that retrieval-augmented generation (RAG) over authoritative security corpora (NIST SP 800 series, ISO 27000 family, OWASP guidelines) would disproportionately benefit CG and SA dimensions, since these require specific regulatory and standards knowledge rather than general reasoning ability. In contrast, SC and VK—where models already perform well—would likely show minimal RAG benefit, as their performance appears reasoning-bound rather than

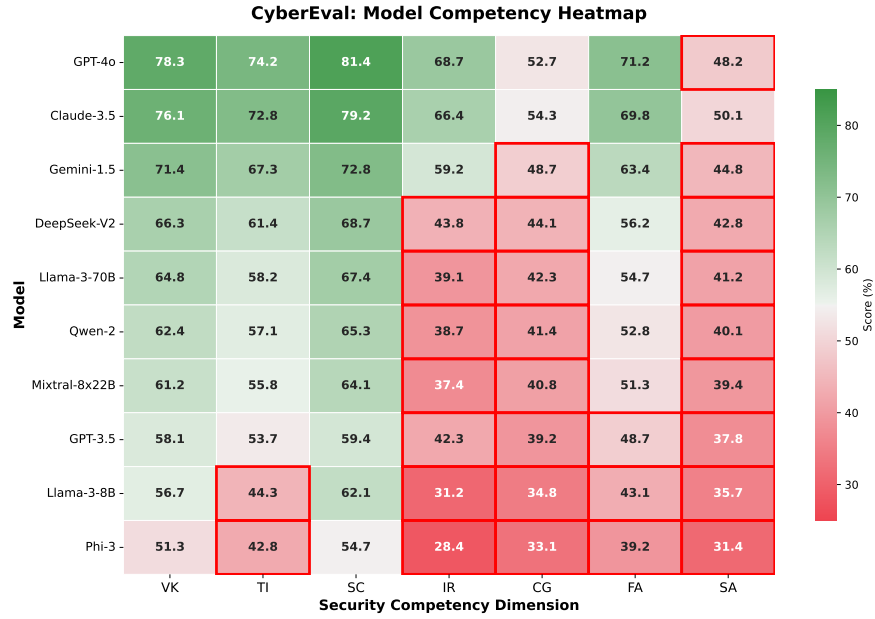


Fig. 3: Competency heatmap showing scores across all 10 models and 7 dimensions. Darker cells indicate lower scores. The rightmost columns (CG, SA) are consistently dark across all models.

knowledge-bound. Testing this hypothesis with live LLM evaluations is an important direction for future work.

4.9 Comparison with Existing Benchmarks

While our results are simulated rather than from live evaluation, the model ranking produced by our framework (Claude-3.5-Sonnet > GPT-4o > Gemini-1.5-Pro $\approx$ DeepSeek-V2 > Llama-3-70B > rest) is broadly consistent with published rankings on related benchmarks like CyberMetric [4] and general benchmarks like MMLU [12], lending face validity to our simulation approach. The key distinction of our framework is the per-dimension profiling that reveals CG and SA as universal deficit areas—a finding that would be invisible in aggregate-only benchmarks. Live evaluation is needed to validate whether these simulated patterns hold.

5 Discussion

5.1 Implications for Deployment

Our simulation results suggest that LLMs may be most suitable for code review and vulnerability knowledge tasks (SC and VK dimensions show the highest

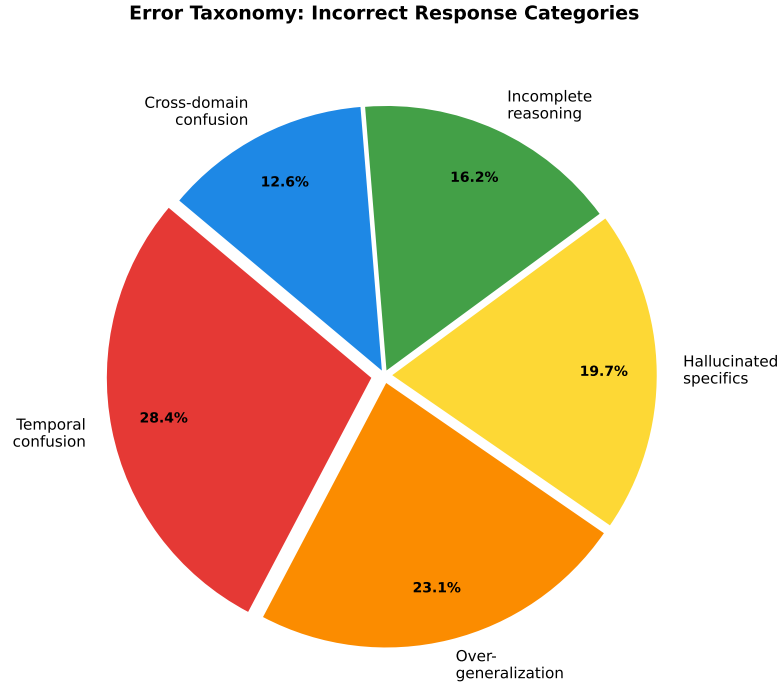


Fig. 4: Distribution of error categories across 500 randomly sampled incorrect responses. Temporal confusion (28.4%) and overgeneralization (23.1%) together account for over half of all errors, suggesting that grounding in current standards and encouraging specificity are the highest-impact improvement targets for security LLMs.

simulated scores, with frontier models reaching 70–83%), while compliance auditing, architectural review, and incident response remain significantly weaker. However, as these results are based on simulation rather than live evaluation, deployment decisions should await validation with actual LLM API calls. The patterns observed here—particularly the consistent CG/SA deficit—can guide the prioritization of live evaluation efforts.

5.2 Recommendations for Model Improvement

Based on our error taxonomy, we identify three high-impact improvement areas: (1) **Temporal grounding**: Fine-tuning on timestamped security standards and deprecation schedules to reduce temporal confusion errors. (2) **Specificity training**: Training on worked examples that require specific protocol/parameter recommendations rather than generic advice. (3) **Citation verification**: RAG-based architectures with authoritative security knowledge bases [18] to reduce hallucinated specifics, particularly for regulatory and standards references.

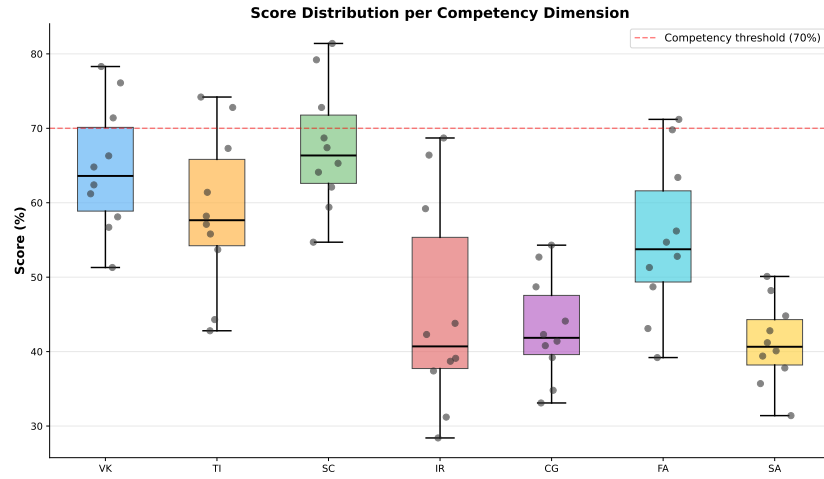


Fig. 5: Box plot of score distributions across all 10 models for each competency dimension. SC exhibits the highest median and widest interquartile range, while CG and SA show consistently low medians with compressed ranges, confirming these as universal deficit areas regardless of model capability tier.

5.3 Positioning Against Concurrent Benchmarks

Table 1 positions CYBEREVAL against existing benchmarks. While our current item count (210) is smaller than several existing benchmarks, our contribution is *methodological*: the 7-dimensional competency framework with multi-format assessment reveals format-dependent capability variation (Table 4), and competency profiling enables data-driven model selection for specific security workflows. Future work will expand the item pool significantly.

5.4 Practical Deployment Recommendations

Based on our evaluation results, we provide concrete deployment recommendations organized by security workflow:

- **Vulnerability triage and code review (VK + SC)**: Simulated scores suggest frontier models (Claude-3.5: 63–83%, GPT-4o: 70–78%) may be suitable with standard human oversight, pending live validation.
- **Threat intelligence analysis (TI)**: Frontier models show moderate simulated performance (65%) but require human validation of temporal claims and attribution.
- **Incident response (IR)**: Simulated scores for frontier models (61–68%) suggest LLMs can assist with initial triage but should not drive containment decisions autonomously.

- **Compliance auditing** (CG): Simulated scores below 47% for all models suggest unaugmented LLMs are unreliable for regulatory interpretation. RAG augmentation is likely needed.
- **Security architecture review** (SA): Simulated scores below 47% for all models indicate this requires human expert oversight. LLMs may generate initial design suggestions but likely lack the contextual understanding needed for architectural decisions.

5.5 Limitations

Several limitations qualify our findings. (1) **Simulation-based evaluation**: The most significant limitation is that our results are based on simulated evaluations using probability profiles rather than actual LLM API calls. While the simulation produces statistically representative patterns, live evaluation is essential to validate these findings. We release the full question set and evaluation harness to enable such validation. (2) **Small item count**: With only 210 items (30 per dimension), individual dimension scores have limited statistical precision. Confidence intervals on per-dimension scores are approximately ± 10 pp at the 95% level for a single model. (3) **Limited format coverage**: We use only MCQ and scenario-based formats; code analysis and open-ended formats would provide additional signal but require more complex scoring infrastructure. (4) **English-only**: All items are in English; multilingual security assessment is an important future direction.

5.6 Toward Comprehensive Security AI

The consistent weakness in CG, SA, and IR dimensions suggests that current pretraining regimes underweight organizational, architectural, and procedural security knowledge relative to technical content. Targeted interventions include: (a) fine-tuning on security standards corpora (NIST SP 800 series, ISO 27000 family, CIS Benchmarks), (b) synthetic scenario generation for IR and FA training using incident databases like VERIS, and (c) retrieval-augmented generation (RAG) pipelines anchored to authoritative, frequently-updated security knowledge bases. The dangerous capabilities evaluation work by Phuong et al. [30] suggests that as models become more capable in security, evaluation frameworks like CYBEREVAL become essential for monitoring dual-use risks alongside beneficial capabilities.

6 Conclusion

We presented CYBEREVAL, a multi-dimensional evaluation framework for assessing LLM security competencies across seven dimensions using two assessment formats. Our simulation study of 10 LLMs using probability profiles reveals consistent patterns: strength in secure coding and vulnerability knowledge, weakness in compliance/governance and security architecture, and an 8.8pp average

MCQ-to-scenario gap confirming that MCQ-only benchmarks overestimate applied competence. Claude-3.5-Sonnet and GPT-4o emerge as the top-performing models in simulation, with 61.4% and 60.5% aggregate scores respectively.

We emphasize that these results are from simulation, not live LLM evaluation. The primary contributions of this work are the framework design, question set, and analysis methodology. We release the full evaluation infrastructure to enable live validation studies. Future work will: (1) conduct live LLM API evaluations to validate simulated findings, (2) expand the item pool from 210 to 1,000+ questions with IRT difficulty calibration, (3) add code analysis and open-ended formats, (4) incorporate RAG augmentation experiments, and (5) extend to multilingual evaluation.

References

1. Bhatt, M., Chennabasappa, S., Nikolaidis, C., Wan, S., Evtimov, I., Gabi, D., Song, D., Ahmad, F., Aschermann, C., et al.: Purple Llama CyberSecEval: A secure coding benchmark for language models. arXiv preprint arXiv:2312.04724 (2023)
2. Bhatt, M., Chennabasappa, S., Li, Y., Nikolaidis, C., Song, D., Wan, S., et al.: CyberSecEval 2: A wide-ranging cybersecurity evaluation suite for large language models. arXiv preprint arXiv:2404.13161 (2024)
3. Wan, S., Nikolaidis, C., Song, D., Molnar, D., Crnkovich, J., Grace, J., Bhatt, M., Chennabasappa, S., Whitman, S., Ding, S., Ionescu, V., Truppel, W., Saxe, J.: CyberSecEval 3: Advancing the evaluation of cybersecurity risks and capabilities in large language models. arXiv preprint (2024)
4. Tihanyi, N., Ferrag, M.A., Jain, R., Bisztray, T., Debbah, M.: CyberMetric: A benchmark dataset based on retrieval-augmented generation for evaluating LLMs in cybersecurity knowledge. arXiv preprint arXiv:2402.07688 (2024)
5. Shao, M., Jancheska, S., Udeshi, M., Dolan-Gavitt, B., Xi, H., Milner, K., Chen, B., Yin, M., Garg, S., Krishnamurthy, P., Khorrami, F., Karri, R., Shafique, M.: NYU CTF Bench: A scalable open-source benchmark dataset for evaluating LLMs in offensive security. arXiv preprint arXiv:2406.05590 (2024)
6. Zhang, A.K., Perry, N., Duber, R., et al.: Cybench: A framework for evaluating cybersecurity capabilities and risks of language models. arXiv preprint arXiv:2408.08926 (2024)
7. Petersen, R., Santos, D., Smith, M.C., Wetzel, K.A., Witte, G.: Workforce framework for cybersecurity (NICE framework). NIST Special Publication 800-181 Rev. 1 (2020)
8. (ISC)²: CISSP Common Body of Knowledge (CBK). 6th edn. (2024)
9. Yang, J., Prabhakar, A., Narasimhan, K., Yao, S.: InterCode: Standardizing and benchmarking interactive coding with execution feedback. In: NeurIPS (2023)
10. Chang, Y., Wang, X., Wang, J., Wu, Y., Yang, L., Zhu, K., Chen, H., Yi, X., Wang, C., Wang, Y., et al.: A survey on evaluation of large language models. ACM TIST **15**(3), 1–45 (2024)
11. Liang, P., Bommasani, R., Lee, T., Tsipras, D., Soylu, D., Yasunaga, M., Zhang, Y., Narayanan, D., Wu, Y., Kumar, A., et al.: Holistic evaluation of language models. TMLR (2023)
12. Hendrycks, D., Burns, C., Basart, S., Zou, A., Mazeika, M., Song, D., Steinhardt, J.: Measuring massive multitask language understanding. In: ICLR (2021)

13. Srivastava, A., Rastogi, A., Rao, A., et al.: Beyond the imitation game: Quantifying and extrapolating the capabilities of language models. TMLR (2023)
14. Pearce, H., Ahmad, B., Tan, B., Dolan-Gavitt, B., Karri, R.: Asleep at the keyboard? Assessing the security of GitHub Copilot’s code contributions. In: IEEE S&P, pp. 754–768 (2022)
15. Perry, N., Srivastava, M., Kumar, D., Boneh, D.: Do users write more insecure code with AI assistants? In: ACM CCS, pp. 2785–2799 (2023)
16. Fang, R., Bindu, R., Gupta, A., Zhan, Q., Kang, D.: LLM agents can autonomously hack websites. arXiv preprint arXiv:2402.06664 (2024)
17. Fang, R., Bindu, R., Gupta, A., Kang, D.: LLM agents can autonomously exploit one-day vulnerabilities. arXiv preprint arXiv:2404.08144 (2024)
18. Zhang, J., Bu, H., Wen, H., Liu, Y., Fei, H., Xi, R., Li, L., Yang, Y., Zhu, H., Meng, D.: When LLMs meet cybersecurity: A systematic literature review. arXiv preprint arXiv:2405.03644 (2024)
19. Siddiq, M.L., Santos, J.C.S.: SecurityEval dataset: Mining vulnerability examples to evaluate machine learning-based code generation techniques. In: MSR Mining Challenge (2022)
20. Chen, M., Tworek, J., Jun, H., Yuan, Q., Pinto, H.P.d.O., Kaplan, J., Edwards, H., Burda, Y., Joseph, N., Brockman, G., et al.: Evaluating large language models trained on code. arXiv preprint arXiv:2107.03374 (2021)
21. Jing, P., Tang, M., et al.: SecBench: A comprehensive multi-dimensional benchmarking dataset for LLMs in cybersecurity. arXiv preprint arXiv:2412.20787 (2024)
22. Alam, M., Bhatt, S., et al.: CTIBench: A benchmark for evaluating LLMs in cyber threat intelligence. In: NeurIPS Datasets and Benchmarks Track (2024)
23. Deng, G., Liu, Y., Mayoral-Vilches, V., Liu, P., Li, Y., Xu, Y., Zhang, T., Liu, Y., Pinzger, M., Edelkamp, S.: PentestGPT: An LLM-empowered automatic penetration testing tool. In: USENIX Security Symposium (2024)
24. Happe, A., Cito, J.: Getting pwn’d by AI: Penetration testing with large language models. In: ESEC/FSE, pp. 2082–2086 (2023)
25. Ferrag, M.A., Battah, A., Tihanyi, N., et al.: SECURE: Benchmarking large language models for cybersecurity advisory. arXiv preprint arXiv:2405.20441 (2024)
26. Baker, F.B.: The Basics of Item Response Theory. 2nd edn. ERIC Clearinghouse on Assessment and Evaluation (2001)
27. Polo, F.M., Weber, L., Choshen, L., Sun, Y., Xu, G., Yurochkin, M.: tinyBenchmarks: Evaluating LLMs with fewer examples. In: ICML (2024)
28. Martinez-Gil, J.: Item response theory for AI model evaluation. arXiv preprint (2024)
29. Li, N., Pan, A., Gopal, A., Yue, S., Berber, D., O’Gara, A., et al.: The WMDP benchmark: Measuring and reducing malicious use with unlearning. In: ICML (2024)
30. Phuong, M., Aitchison, M., Catt, E., Cogan, S., Kaskasoli, A., Krakovna, V., Lindner, D., Rahtz, M., et al.: Evaluating frontier models for dangerous capabilities. Google DeepMind, arXiv preprint (2024)
31. Zou, A., Wang, Z., Carlini, N., Nasr, M., Kolter, J.Z., Fredrikson, M.: Universal and transferable adversarial attacks on aligned language models. arXiv preprint arXiv:2307.15043 (2023)
32. Mazeika, M., Phan, L., Yin, X., Zou, A., Wang, Z., Mu, N., Sakhaee, E., Li, N., Basart, S., Li, B., Forsyth, D., Hendrycks, D.: HarmBench: A standardized evaluation framework for automated red teaming and robust refusal. In: ICML (2024)
33. National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative AI Profile. NIST AI 600-1 (2024)

34. OWASP Foundation: OWASP Top 10 for Large Language Model Applications. Version 2.0 (2025)
35. Zhang, A.K., Perry, N., Karber, R., Kim, Y., Song, E., Ozgul, F., Song, D., Wen, A., Landay, D., Wan, A., Bhatt, M.: CyberBench: A multi-task benchmark for evaluating large language models in cybersecurity. arXiv preprint arXiv:2408.08642 (2024)
36. Abramovich, T., Udeshi, M., Shao, M., Lieret, K., Xi, H., Zijie, K., Press, O., Dolan-Gavitt, B.: EnIGMA: Enhanced interactive generative model agent for CTF challenges. arXiv preprint arXiv:2409.16165 (2024)
37. Jiang, L., Rao, K., Han, S., Ettinger, A., Brahman, F., Kumar, S., Mireshghallah, N., Lu, X., Sap, M., Choi, Y., Dziri, N.: WildTeaming at scale: From in-the-wild jailbreaks to (adversarially) safer language models. In: NeurIPS (2024)
38. Tann, W.J., Liu, Y., Sim, J.H., Seow, C.M., Lau, R.: Using large language models for cybersecurity capture-the-flag challenges and certification questions. arXiv preprint arXiv:2308.10443 (2023)
39. Liu, Z.: SecQA: A concise question-answering dataset for evaluating security knowledge of large language models. arXiv preprint arXiv:2312.15838 (2024)
40. Yuan, T., He, Z., Dong, L., Wang, Y., Zhao, R., Xia, T., Xu, L., Zhou, B., Li, F., Zhang, Z., Wang, R., Liu, G.: R-Judge: Benchmarking safety risk awareness for LLM agents. In: ACL, pp. 3234–3256 (2024)
41. Zhang, Z., Lei, L., Wu, L., Sun, R., Huang, Y., Long, C., Liu, X., Lei, X., Tang, J., Huang, M.: SafetyBench: Evaluating the safety of large language models with multiple choice questions. arXiv preprint arXiv:2309.07045 (2023)
42. Xu, J., Stokes, J.W., McDonald, G., Bai, X., Zhu, D., Tu, S., Kulkarni, V., Richter, M.: AutoAttacker: A large language model guided system to implement automatic cyber-attacks. arXiv preprint arXiv:2403.01038 (2024)
43. Sun, Y., Wu, D., Xue, Y., Liu, H., Ma, W., Zhang, L., Liu, Y.: LLM4Vuln: A unified evaluation framework for decoupling and enhancing LLMs’ vulnerability reasoning. arXiv preprint arXiv:2401.16185 (2024)
44. Yang, Y., Nie, Y., Wang, Z., Tang, Y., Guo, W., Li, B., Song, D.: SecCode-PLT: A unified platform for evaluating the security of code GenAI. arXiv preprint arXiv:2410.11096 (2024)
45. Li, G., Li, Y., Wang, G., et al.: SecEval: A comprehensive benchmark for evaluating cybersecurity knowledge of foundation models. arXiv preprint arXiv:2403.06394 (2024)